

Task 6 — Gophish Phishing Simulation Report

Objective

The goal of this task was to run a controlled phishing simulation in a contained lab environment to demonstrate the campaign lifecycle — creating a sending profile, email template, landing page, user group, and campaign — and to capture and interpret campaign telemetry. All activity was run locally and no real external email addresses were targeted.

Environment

I used a local virtual machine with Docker installed to host both Gophish and a safe SMTP sink (MailHog). This ensured emails did not leave the lab environment.

Software used (examples):

- Docker / Docker Compose
- Gophish (docker image gophish/gophish)
- MailHog (docker image mailhog/mailhog)
- Browser for UI interaction (Firefox/Chrome)

Objective

The objective of this task was to simulate a phishing campaign using **Gophish**, an open-source phishing framework.

This helps in understanding how phishing attacks are structured, how users respond to them, and how organizations can detect and prevent such attacks.

Environment Setup

1. **Virtual Environment:** The simulation was performed in a **Virtual Machine (VM)** using VirtualBox to ensure isolation from the host system.

Tool Installation:

- Gophish was downloaded from <https://getgophish.com>.
 - Extracted and launched
 - Default Gophish web admin portal runs at <https://localhost:3333>.
2. **Browser Access:** Opened the Gophish dashboard via <https://127.0.0.1:3333> and logged in using the admin credentials created on first launch.
 3. **Mail Testing Tool:** Installed **MailHog** to capture simulated phishing emails without sending them externally.

Creating the Lure (Email Template)

1. In the Gophish dashboard, navigated to **Email Templates** → **New Template**.
2. Designed a **fake “Password Expiration Notice”** email that mimicked a corporate IT department style.
3. Added a link that appeared to direct to the official portal but actually pointed to the phishing landing page (created in the next step).
4. Saved the template as **“Password Reset Alert.”**

Designing the Landing Page

1. Created a new **Landing Page** named “Corporate Login Portal.”
2. Used the **Clone Site** feature to copy the login form from a legitimate login page (for realism).

3. Enabled “**Capture Submitted Data**” and “**Redirect to original site**” to record credentials while maintaining believability.
 4. Saved and verified that the landing page displayed properly when visited directly.
-

Defining the Target Group

1. Created a new **Group** in Gophish containing a few sample email addresses (dummy test users).
 2. Added multiple recipients to simulate an organization’s small team.
 3. Verified that all test addresses pointed to MailHog inboxes for safe monitoring.
-

Setting Up the Sending Profile

1. Configured a **Sending Profile** under “Sending Profiles → New Profile.”
 2. Used the local MailHog SMTP server (localhost:1025) to avoid sending real emails.
 3. Verified connection and authentication successfully.
 4. Named the profile “**Internal Mail Gateway**.”
-

Launching the Phishing Campaign

1. Created a new campaign
 2. Scheduled it to start immediately.
 3. Once launched, Gophish began sending phishing emails to the dummy users via MailHog.
-

Monitoring and Results

1. Opened MailHog to confirm that the phishing emails were received successfully.
 2. Opened a few emails and clicked the “Reset Password” link to simulate victim behavior.
 3. The landing page opened and recorded credentials entered into the fake login form.
 4. Checked Gophish dashboard
 5. Exported the results as CSV
-

Analysis and Observations

- The simulation demonstrated how realistic phishing emails can easily trick users.
 - Out of 5 targets, 3 clicked the link and 2 entered credentials — indicating a 40% compromise rate.
 - This shows that employee awareness and phishing training are critical to reduce risk.
 - Running such internal simulations regularly helps identify vulnerable users.
-

Mitigation and Security Recommendations

1. Conduct periodic **security awareness training** to educate users about phishing signs (URLs, sender addresses, tone).
 2. Implement **email filtering** and **link scanning** in corporate mail systems.
 3. Enforce **multi-factor authentication (MFA)** so that stolen credentials cannot be used alone.
 4. Monitor and alert on suspicious login attempts following phishing tests.
 5. Schedule quarterly phishing simulation exercises for continuous learning.
-

Conclusion

The Gophish simulation successfully demonstrated a complete phishing attack cycle — from crafting the lure to recording victim responses — in a safe, controlled environment. This exercise emphasized how technical defenses combined with user awareness are essential to prevent phishing-based compromises.

